Année de Formation 2025/2026

M205: Développer en back end

TP: CSRF (Cross-Site Request Forgery)

Objectif du TP

Comprendre ce qu'est une attaque **CSRF**, comment elle se produit et comment Laravel protège contre ce type d'attaque.

Partie 1 : Création d'une application Laravel

Créer un nouveau projet Laravel : **TPCSRF**

Syntaxe :

```
composer create-project laravel/laravel TPCSRF
cd TPCSRF
php artisan serve
```

Création d'une route et d'un contrôleur :

Créez une route pour afficher un formulaire de changement de mot de passe et une autre pour traiter le formulaire.

Syntaxe :

```
// routes/web.php
Route::get('/change-password', [PasswordController::class, 'showForm']);
Route::post('/change-password', [PasswordController::class, 'changePassword']);
```

```
// app/Http/Controllers/PasswordController.php
namespace App\Http\Controllers;
use Illuminate\Http\Request;

class PasswordController extends Controller
{
    public function showForm()
    {
        return view('change-password');
    }

    public function changePassword(Request $request)
    {
        // Logique de changement de mot de passe
        return 'Mot de passe changé !';
    }
}
```

Création du formulaire :

Créez un fichier Blade pour le formulaire.

Syntaxe :

```
 <!-- resources/views/change-password.blade.php -->
<form action="/change-password" method="POST">
    @csrf <!-- Token CSRF -->
    <input type="password" name="new_password" required>
    <button type="submit">Changer le mot de passe</button>
</form>
```

Partie 2 : Démonstration de l'attaque CSRF

1. **Créer une page malveillante**:

- Créez un fichier HTML externe qui tentera d'exécuter l'attaque CSRF. Par exemple :

Syntaxe :

```
<!-- malicious.html -->
<html>
<body>
    <form action="http://localhost:8000/change-password" method="POST">
        <input type="hidden" name="_token" value="TOKEN_DU_SITE_VICTIME">
        <input type="hidden" name="new_password" value="attackerPassword">
        <button type="submit">Changer le mot de passe</button>
    </form>
</body>
</html>
```

Remplacez ***TOKEN_DU_SITE_VICTIME*** par un token valide (que vous pouvez trouver dans l'application Laravel en inspectant les formulaires avec le token CSRF).

2. **Démonstration** :

✓ Ouvrez **malicious.html** dans le navigateur et montrez comment, sans protection CSRF, l'attaque pourrait réussir.

Partie 3 : Protection contre les attaques CSRF avec Laravel

1. **Utiliser le middleware CSRF** :
    - Expliquez que Laravel inclut automatiquement un middleware qui protège les routes contre les attaques CSRF.
2. **Vérifier la protection** :
    - Retirez temporairement le token CSRF dans le formulaire pour montrer que Laravel renverra une erreur **419** (***Page Expired)*** lorsqu'on essaie de soumettre le formulaire.